



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



JFrog Artifactory Authentication Chain and Backdoor Campaign

Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-09-15
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | JFrog Artifactory Authentication Chain and Backdoor Campaign - Vulnerability Threat Intelligence Report

Published: 2026-09-15 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review and Confidence
4. Vulnerability Details
5. Attack Scenarios
 - 5.1. Scenario 1: Internet-Exposed Self-Hosted Artifactory Chain
 - 5.2. Scenario 2: Standalone CVE-2026-82329 Administrative Bypass
 - 5.3. Scenario 3: Supply-Chain Persistence After Patch
6. Threat Landscape and Exploitation Status
7. Affected Products and Exposure
8. Indicators, Observables, and Source Limitations
9. MITRE ATT&CK Mapping
10. Mitigation and Workarounds
11. Detection Engineering
 - 11.1. Detection Logic Summary
 - 11.2. Sigma Rule
 - 11.3. Suricata IOC Rules
12. Threat Hunting
 - 12.1. Artifactory Exploit Sequence Hunt (KQL)
 - 12.2. Admin Account Pattern Hunt (KQL)
 - 12.3. Linux Host Persistence and Payload Hunt (KQL)
13. Validation and Lab Testing
14. Incident Response and Containment
15. Recommended Actions Summary
16. References

JFrog Artifactory Authentication Chain and Backdoor Campaign

1. Executive Summary

BLUF: Multiple actors are exploiting self-hosted JFrog Artifactory authentication and authorization flaws to turn unauthenticated network access into administrator control, create persistent admin users, deploy malicious Groovy plugins, steal configuration material, and stage a Rust-based backdoor. This is a software-supply-chain control-plane incident class, not a simple patch-only vulnerability note.

The primary chain observed by Wiz combines CVE-2026-42018 and CVE-2026-42016. CVE-2026-42018 can expose an internal anonymous-user token to an unauthenticated requester; CVE-2026-42016 can let that low-privilege token be exchanged for administrator scope because token scope is not properly enforced. Wiz observed exploitation of that chain between 2026-08-15 and 2026-09-08. Separately, CVE-2026-82329 allows unauthenticated administrative access on affected branches and was observed exploited between 2026-09-01 and 2026-09-08.

Patching is urgent, but insufficient. Defender response must include token revocation, join-key rotation where relevant, review of administrator accounts, plugin inspection, repository/configuration audit, and hunting for post-exploitation artifacts that survive an upgrade.

Field	Assessment
Report ID	LBC-VTI-2026-1330
Classification	TLP:CLEAR
Severity	Critical for exposed vulnerable self-hosted Artifactory; High for internally reachable instances
Confidence	High for vulnerability details and observed patterns from JFrog/Wiz/CISA/NVD reporting
Primary Risk	Build artifact control-plane takeover, poisoned supply-chain trust, credential/token theft, persistent backdoor access
Immediate Action	Patch to fixed branch versions, restrict exposure, revoke suspicious tokens, remove rogue admins/plugins, rotate join keys/secrets

2. Vulnerability Metadata

CVE	Vulnerability Class	Operational Effect	Affected Versions / Fixed Guidance
CVE-2026-42018	Improper authentication / anonymous token exposure	Unauthenticated request can receive an internal anonymous-user token even when anonymous access is disabled	JFrog lists affected Artifactory ranges below 7.111.20, 7.117.0-7.117.27, 7.125.0-7.125.19, 7.133.0-7.133.28, and 7.146.0-7.146.8.
CVE-2026-42016	Incorrect authorization / token scope validation flaw	Low-privilege token can be escalated to administrator scope	JFrog lists self-hosted Artifactory before 7.133.11 as affected.
CVE-2026-82329	Authentication bypass	Unauthenticated attacker with network access can obtain administrator privileges without chaining another flaw	JFrog lists affected ranges across 7.111.4-7.111.21, 7.117.0-7.117.27, 7.125.0-7.125.19, 7.133.0-7.133.28, 7.146.0-7.146.36, and 7.161.0-

			7.161.19; fixed versions include 7.111.21, 7.117.28, 7.125.20, 7.133.29, 7.146.38, and 7.161.20 or later per Wiz/JFrog reporting.
--	--	--	---

3. Source Review and Confidence

Source	What It Contributes	Confidence
JFrog Security Advisories	Vendor affected versions, fixed branches, and workaround notes	High
Wiz Research	In-the-wild exploitation timelines, observed request patterns, post-exploitation behaviors, IOCs, rogue account names	High
The Hacker News	Secondary synthesis of exploitation, patching, and compromise-assessment implications	Medium-High
CISA KEV	Independent confirmation that relevant Artifactory vulnerabilities are exploited in the wild	High
NVD CVE records	CVE metadata and standardized vulnerability descriptions	High

Analytic caveat: no victim-owned telemetry or malware sample was provided with this request. This report therefore focuses on source-backed vulnerability intelligence, detection logic, and response guidance rather than asserting a specific environment is compromised.

4. Vulnerability Details

The two-flaw chain matters because neither CVE-2026-42018 nor CVE-2026-42016 alone needs to deliver full administrator control. In combination, they can move from unauthenticated access to administrator-scoped token authority in minutes:

Step	Request / Behavior	Defender Interpretation
1	POST /access/api/v1/aws/token/ returns HTTP 200 with an internal anonymous-user JWT	Possible CVE-2026-42018 exploitation; trailing slash behavior is a key signal.
2	POST /access/api/v1/tokens returns HTTP 200 with an admin-scoped token	Possible CVE-2026-42016 scope-validation abuse.
3	Later administrator actions appear as token:anonymous or anonymous-derived identity	Log identity can be misleading because authority changed while username stayed anonymous.
4	PUT /api/security/users/<username> or /access/api/ui/users/<username> returns HTTP 201	Persistent administrator account creation.

CVE-2026-82329 is a separate critical path. Wiz describes successful exploitation as POST /access/api/v1/registry/join returning HTTP 200 or 201 with an admin-scoped token in the response body, followed by account creation, configuration access, token enumeration, user enumeration, or join-key retrieval.

5. Attack Scenarios

5.1. Scenario 1: Internet-Exposed Self-Hosted Artifactory Chain

An attacker identifies an exposed Artifactory node running versions affected by both CVE-2026-42018 and CVE-2026-42016. They request the AWS token endpoint with the vulnerable path variant, receive the internal anonymous-user token, exchange it for administrator scope, and create a new admin account. Within the same session, the attacker installs a malicious Groovy plugin and uses the plugin execution endpoint to run shell commands.

5.2. Scenario 2: Standalone CVE-2026-82329 Administrative Bypass

An attacker sends POST /access/api/v1/registry/join to an affected instance and receives an administrator-scoped token. They query system configuration, enumerate users and tokens, retrieve the join key, then create one or more accounts with names that resemble product components or service users. Patching after the fact does not remove the accounts, minted tokens, or stolen secrets.

5.3. Scenario 3: Supply-Chain Persistence After Patch

An organization patches Artifactory but does not investigate pre-patch activity. A malicious admin account, uploaded webshell, Groovy plugin, or stolen join key remains available. The attacker returns through a non-CVE path and manipulates artifacts, credentials, or CI/CD trust relationships.

6. Threat Landscape and Exploitation Status

Signal	Assessment
Exploitation timeline	Wiz observed CVE-2026-42018/CVE-2026-42016 chained exploitation from 2026-08-15 to 2026-09-08 and CVE-2026-82329 exploitation from 2026-09-01 to 2026-09-08.
Operators	Multiple actors; Wiz explicitly notes no single actor performed every observed post-exploitation step.
Time to persistence	Wiz reported cases where actors moved from initial request to created admin account in under five minutes.
Post-exploitation	Rogue admin users, malicious Groovy plugins, shell command execution, second-stage payload delivery, webshell upload, configuration access, join-key theft.
Malware	Wiz observed a custom Rust backdoor with C2 capabilities in multiple cases.
Supply-chain blast radius	Artifactory can hold packages, containers, AI models, binaries, build metadata, secrets-adjacent deployment tokens, and trust anchors used by CI/CD systems.

7. Affected Products and Exposure

Asset Pattern	Risk Driver	Priority
Internet-facing self-hosted Artifactory	Remote unauthenticated exploitation paths are documented	Immediate
Partner/developer reachable Artifactory	Lower exposure than internet-facing, but still reachable by compromised VPN, SSO, or developer endpoint	High
Artifactory integrated with CI/CD tokens	Admin compromise can lead to build-	Immediate

	pipeline, package, deployment, or signing impact	
Patched but uninvestigated instances	Patch does not revoke tokens, remove rogue users, delete malicious plugins, or rotate stolen join keys	Immediate
JFrog Cloud	JFrog/THN reporting indicates cloud instances require no customer action for these self-hosted fixes	Monitor vendor notifications

8. Indicators, Observables, and Source Limitations

Observable	Type	Why It Matters
hxxp://log.gitclone[.]org:45678/smtp	URL	Payload download after CVE-2026-42018/CVE-2026-42016 exploitation.
hxxp://3.88.162[.]79:36789/smtp	URL	Second-stage payload download after chained exploitation.
513a907b69edffc3cb77a494da395178d21ef9bd	SHA1	Reported SHA1 of /tmp/.z payload.
64.207.232[.]6:8443	C2 IP:port	C2 address reported by Wiz.
token:anonymous performing administrator actions	Account behavior	High-signal indicator of token scope mismatch or anonymous-derived admin activity.
svc_[a-zA-z0-9]{8}, Nxploited_[a-zA-z0-9]{3}, labadmin_[a-zA-z0-9]{10}	Account regex	Reported malicious account naming patterns.
jfrog-distribution, jfrog-insight, repo-service, backup-service, migration-tool, ldap_admin, ldap_administrator, 0xterror	Account names	Reported malicious admin account names.

The full IOC sidecar is preserved in iocs.csv. Treat actor IPs as time-bound hunting pivots rather than permanent blocklist entries without local validation.

9. MITRE ATT&CK Mapping

Tactic	Technique	Evidence / Rationale
Initial Access	T1190 Exploit Public-Facing Application	Artifactory HTTP API exploitation against exposed self-hosted instances.
Persistence	T1136.001 Create Account: Local Account	Creation of persistent Artifactory admin users.
Persistence / Privilege Escalation	T1098 Account Manipulation	Token minting, administrator scope elevation, and SSH-key attachment.
Execution	T1059.004 Unix Shell	Shell commands executed through plugin endpoints on Linux-hosted Artifactory.
Persistence	T1505.003 Server Software Component:	Webshell/script upload to repository paths

	Web Shell	reported in observed activity.
Command and Control	T1105 Ingress Tool Transfer	Payload fetched over HTTP into /tmp, /dev/shm, or /var/tmp.
Command and Control	T1071.001 Web Protocols	HTTP payload staging and observed C2 communication.
Credential Access	T1552.001 Credentials In Files	Configuration and join-key access from compromised nodes.

10. Mitigation and Workarounds

1. Upgrade affected self-hosted Artifactory instances to the fixed build for the deployed release branch. Prioritize internet-facing systems first.
2. Restrict Artifactory access to trusted networks, VPNs, identity-aware proxy, or zero-trust access controls. Do not leave administrative endpoints broadly reachable.
3. Revoke access tokens minted during suspected exposure windows. Pay special attention to tokens associated with anonymous, low-privilege, or newly created service-like users.
4. Review and remove unexpected administrator accounts, especially names matching published malicious patterns or names created outside approved change windows.
5. Inspect Artifactory plugin directories and plugin execution logs for unapproved Groovy plugins or suspicious plugin execution endpoints.
6. Rotate the platform join key and other shared secrets if CVE-2026-82329 exploitation, configuration reads, or /access/api/v1/system/security/join_key access are suspected.
7. Audit repositories for unexpected uploads, webshell-like scripts, package replacement, altered metadata, or new artifacts published by suspicious users.
8. Preserve logs before cleanup: access logs, request logs, audit/security logs, access-service logs, plugin logs, system configuration access records, and CI/CD job history.

For CVE-2026-82329 emergency mitigation where immediate upgrade is blocked, JFrog describes adding a strong additionalJoinKeys value under shared.security in system.yaml or using the equivalent

JF_SHARED_SECURITY_ADDITIONALJOINKEYS environment variable, then restarting Access/JPD. This workaround is not a replacement for patching or compromise assessment.

11. Detection Engineering

11.1. Detection Logic Summary

Detection Hypothesis	Telemetry	High-Fidelity Signal
If CVE-2026-42018 is being probed or exploited, access logs will show POST requests to /access/api/v1/aws/token/ with unusual 401 then 200/201 behavior from the same client.	Artifactory access logs / reverse proxy logs	401 on bare path followed by 200/201 on trailing-slash variant within a short window.
If CVE-2026-42016 is abused, anonymous or low-privileged identity will mint tokens or perform admin-only actions.	Access-service logs / security audit logs	token:anonymous or anonymous identity using /access/api/v1/tokens, /artifactory/api/security/token, user APIs, or plugin APIs.

If CVE-2026-82329 is exploited, registry join endpoint use will precede admin-token activity or configuration access.	Access logs / audit logs	POST /access/api/v1/registry/join returning 200/201 followed by user/token/config reads.
If persistence was established, new admin accounts or Groovy plugins will appear outside approved change windows.	Artifactory audit logs / filesystem / configuration management	Username matching reported patterns or plugin execution after suspicious token creation.

11.2. Sigma Rule

```

title: JFrog Artifactory Exploit Chain and Suspicious Admin Actions
id: 69c121df-1af3-4f6e-bc27-c38f63291c7c
status: experimental
description: Detects Artifactory access/application log patterns associated with CVE-2026-42018,
CVE-2026-42016, and CVE-2026-82329 exploitation followed by admin-token or account activity.
references:
  - https://www.wiz.io/blog/artifactory-under-attack-in-the-wild-exploitation-of-cve-2026-42016-cve-2026-4201
  - https://thehackernews.com/2026/09/attackers-chain-jfrog-artifactory-flaws.html
author: Lost Boys Cyber
date: 2026-09-15
tags:
  - attack.initial_access
  - attack.t1190
  - attack.persistence
  - attack.t1136.001
  - attack.t1098
logsource:
  product: linux
  service: webserver
detection:
  selection_chain_token:
    request_method: 'POST'
    url|contains: '/access/api/v1/aws/token/'
    status:
      - 200
      - 201
  selection_admin_token:
    request_method: 'POST'
    url|contains:
      - '/access/api/v1/tokens'
      - '/artifactory/api/security/token'
    user|contains:
      - 'token:anonymous'
      - 'anonymous'
  selection_registry_join:
    request_method: 'POST'
    url|contains: '/access/api/v1/registry/join'
    status:
      - 200
      - 201
  selection_persistence:
    request_method: 'PUT'
    url|contains:
      - '/api/security/users/'
      - '/access/api/ui/users/'
    status:
      - 200
      - 201
  selection_plugin_exec:
    url|contains:
      - '/api/plugins/execute/'
      - '/artifactory/api/plugins'
filter_known_admin:

```



```

user|contains:
- 'known-ci-admin'
- 'known-artifactory-admin'
condition: (selection_chain_token or selection_admin_token or selection_registry_join or
selection_persistence or selection_plugin_exec) and not filter_known_admin
fields:
- src_ip
- user
- request_method
- url
- status
- user_agent
falsepositives:
- Legitimate administrative API automation; baseline known service accounts and require change-ticket
correlation for user creation/plugin deployment.
level: high

```

11.3. Suricata IOC Rules

```

alert http any any -> any any (msg:"LBC JFrog Artifactory exploit payload download log.gitclone.org
smtp path"; flow:to_server,established; http.host; content:"log.gitclone.org"; nocase; http.uri;
content:"/smtp"; classtype:trojan-activity; sid:9001330; rev:1; metadata:created_at 2026_09_15;)
alert http any any -> 3.88.162.79 any (msg:"LBC JFrog Artifactory exploit second-stage payload download
to 3.88.162.79 smtp path"; flow:to_server,established; http.uri; content:"/smtp"; classtype:trojan-
activity; sid:9001331; rev:1; metadata:created_at 2026_09_15;)
alert ip any any -> 64.207.232.6 8443 (msg:"LBC JFrog Artifactory Rust backdoor C2 64.207.232.6:8443";
classtype:trojan-activity; sid:9001332; rev:1; metadata:created_at 2026_09_15;)

```

12. Threat Hunting

12.1. Artifactory Exploit Sequence Hunt (KQL)

```

let lookback = 30d;
let attacker_ips =
dynamic(['149.102.229.150','186.247.79.240','182.62.201.69','146.19.216.120','185.190.58.172','45.61.17
6.88','223.144.227.110','129.121.56.234','16.54.250.190','105.188.75.16','103.124.165.42','176.88.121.1
52','155.254.120.23','220.246.124.92','15.157.64.113','104.28.251.139','137.184.111.69']);
ArtifactoryAccess_CL
| where TimeGenerated > ago(lookback)
| where SrcIp_s in (attacker_ips)
  or Url_s has_any ('/access/api/v1/aws/token/', '/access/api/v1/tokens',
'/artifactory/api/security/token', '/access/api/v1/registry/join', '/api/security/users/',
'/access/api/ui/users/', '/api/plugins/execute/', '/artifactory/api/plugins')
  or User_s has 'token:anonymous'
| summarize Events=count(), Methods=make_set(Method_s, 10), Statuses=make_set(StatusCode_s, 10),
Urls=make_set(Url_s, 20), Users=make_set(User_s, 20), UserAgents=make_set(UserAgent_s, 10) by SrcIp_s,
bin(TimeGenerated, 15m)
| order by TimeGenerated desc

```

12.2. Admin Account Pattern Hunt (KQL)

```

let lookback = 45d;
let suspicious_names = dynamic(['jfrog-distribution','backup-service','repo-service','jfrog-
insight','jfrog-mission-control','jfrog-pipeline','migration-
tool','ldap_admin','ldap_administrator','0xterror']);
ArtifactoryAudit_CL
| where TimeGenerated > ago(lookback)
| where Action_s has_any ('create user','update user','admin','token','ssh key')
| where TargetUser_s in~ (suspicious_names)
  or TargetUser_s matches regex @'^(\svc_[A-Za-z0-9]{8}|Nxploited_[A-Za-z0-9]{3}|labadmin_[A-Za-z0-9]
{10})$'
  or Actor_s has_any ('token:anonymous','anonymous')
| project TimeGenerated, Actor_s, Action_s, TargetUser_s, SrcIp_s, Outcome_s, Details_s
| order by TimeGenerated desc

```

12.3. Linux Host Persistence and Payload Hunt (KQL)

```
DeviceFileEvents
```

```

| where Timestamp > ago(30d)
| where FolderPath has_any ('/tmp/', '/dev/shm/', '/var/tmp/')
| where SHA1 == '513a907b69edffc3cb77a494da395178d21ef9bd'
|   or FileName in~ ('.z','smtp')
|   or InitiatingProcessCommandLine has_any ('log.gitclone.org', '3.88.162.79:36789', '64.207.232.6')
| project Timestamp, DeviceName, FolderPath, FileName, SHA1, InitiatingProcessFileName,
InitiatingProcessCommandLine
| order by Timestamp desc

```

13. Validation and Lab Testing

Validation Step	Expected Result	Notes
Parser test	Access-log fields map to method, URL, status, user, source IP, and user-agent fields used by detections	Adjust Sigma/KQL field names to local parser.
Negative baseline	Legitimate CI/CD token creation and plugin administration do not produce high alert volume after known-admin filters	Maintain allowlist by service account and change window.
Historical backtest	Searches over 30-45 days identify any suspicious endpoint, token:anonymous, or rogue account activity	Investigate hits before assuming false positives.
Host follow-up	Affected nodes are searched for /tmp/.z, suspicious binaries in /tmp, /dev/shm, /var/tmp, and unknown Groovy plugin files	Preserve samples for malware analysis if found.

14. Incident Response and Containment

9. Snapshot logs and configuration before remediation where feasible.
10. Isolate or restrict exposed Artifactory instances while preserving business-critical build continuity.
11. Upgrade to fixed versions and apply the JFrog workaround only as temporary risk reduction if patching is blocked.
12. Disable and investigate unknown administrator accounts. Do not delete evidence before recording creation time, creator identity, source IP, API path, and associated token IDs.
13. Revoke suspicious tokens and rotate CI/CD credentials, repository deploy keys, package-publishing credentials, and Artifactory join keys if exposure is plausible.
14. Remove malicious plugins, repository webshells, and staged payloads after evidence collection.
15. Rebuild trust in artifact repositories: verify critical package checksums, validate recent artifact publishers, and review promotion/signing workflow integrity.

15. Recommended Actions Summary

Priority	Action	Owner
P0	Inventory self-hosted Artifactory versions and internet exposure	Vulnerability Management / Platform
P0	Patch to fixed branch versions or later	Platform / DevOps
P0	Hunt for token endpoint, registry join, token:anonymous, rogue admin, plugin execution, and IOC activity	Detection Engineering / SOC
P1	Rotate join keys, access tokens, CI/CD	Platform / Identity

	secrets, and deploy keys where exploitation cannot be ruled out	
P1	Audit recent artifacts, repositories, and build-pipeline trust paths	DevOps / AppSec
P2	Add recurring detections for Artifactory administrative API misuse and plugin deployment	Detection Engineering
P2	Tabletop a software-supply-chain compromise scenario involving artifact repository takeover	Security Leadership / IR

16. References

- [1] The Hacker News: Attackers Chain JFrog Artifactory Flaws to Gain Admin Control and Plant Backdoors — <https://thehackernews.com/2026/09/attackers-chain-jfrog-artifactory-flaws.html>
- [2] Wiz Research: Artifactory Under Attack — <https://www.wiz.io/blog/artifactory-under-attack-in-the-wild-exploitation-of-cve-2026-42016-cve-2026-4201>
- [3] JFrog Security Advisories — <https://docs.jfrog.com/releases/docs/jfrog-security-advisories>
- [4] CISA Known Exploited Vulnerabilities Catalog — <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- [5] NVD CVE-2026-42016 — <https://nvd.nist.gov/vuln/detail/CVE-2026-42016>
- [6] NVD CVE-2026-42018 — <https://nvd.nist.gov/vuln/detail/CVE-2026-42018>
- [7] NVD CVE-2026-82329 — <https://nvd.nist.gov/vuln/detail/CVE-2026-82329>